

MISSION BRIEF

Day 2: macOS Miner Attack Chain

ANALYST

Eswar Mahalingam
Blue Team Operator & Trainee

PROGRAMME

DSOU — GraySentinel

OPERATOR ID

GS-STU-DSOU-2026-039A

DATE

10 September 2026

CVE FOCUS

CVE-2026-65400

macOS Screen Sharing

Pre-auth RCE via SRP

CVSS 9.8 — Critical

ATTACK PHASES

- 1 Phishing / oletools
- 2 CVE-2026-65400 Exploit
- 3 AdaptixC2 + SSH Backdoor
- 4 XMRig Miner Deploy
- 5 OSINT / Attribution
- 6 Detection & Remediation

TOOLS USED

- oletools (olevba/oleid)
- poc_screensharing.py
- AdaptixC2 (Go C2)
- XMRig 6.26.0
- Tookie-OSINT
- dig (DNS)
- Wazuh SIEM rules

RISK SUMMARY

Critical	4
High	5
Medium	3
Total	170+

MITRE ATT&CK;

- T1566 Phishing
- T1203 Exploit Public App
- T1059 Command & Scripting
- T1543 Create/Modify Service
- T1496 Resource Hijacking
- T1098 Account Manipulation
- T1071 App Layer Protocol

DAY 2 — macOS Miner Attack Chain

GraySentinel DSOU Lab Report · Blue Team Incident Analysis

EXECUTIVE SUMMARY

This report documents the complete analysis of a macOS cryptomining attack chain observed in the GraySentinel DSOU Day 2 training environment. The attacker leveraged a VBA macro-laced phishing document to deliver an initial downloader, exploited CVE-2026-65400 (a pre-authentication Remote Code Execution vulnerability in macOS Screen Sharing, CVSS 9.8) to gain root access, deployed the AdaptixC2 post-exploitation framework for persistent command-and-control, installed XMRig 6.26.0 masquerading as the system process *sysmond* for covert Monero mining, and established a LaunchDaemon KeepAlive persistence mechanism alongside an SSH root backdoor. A total of 170 risks were identified across the attack chain. OSINT attribution via Tookie-OSINT and DNS analysis identified attacker infrastructure, enabling blocking and full remediation.

6 Phases Completed	170+ Risks Identified	4 Critical Findings	CVE-2026-65400 CVSS 9.8 Core CVE	5 ATT&CK; Tactics
-----------------------	--------------------------	------------------------	-------------------------------------	----------------------

PHASE-BY-PHASE FINDINGS

1	Phishing Email Analysis (oletools)	Initial Access — T1566 + T1059
olevba revealed an AutoExec macro using URLDownloadToFile to fetch a second-stage payload from the attacker's C2 server without user interaction. oleid confirmed OLE structure with external relationships to attacker-controlled domains (attacker-domain.com). Macro ran on document open, bypassing user consent entirely.		
#2	VBA Download Cradle URLDownloadToFile fetches payload silently	High
#3	No Macro Security Controls AutoExec bypasses user interaction	High
#4	Suspicious External Relationships C2 domain embedded in document	Medium
2	CVE-2026-65400 Exploitation	Exploitation — T1203
poc_screensharing.py exploited the SRP frame-length validation flaw in macOS Screen Sharing (port 5900) to bypass authentication without credentials, achieving code execution as root. A second invocation read /etc/passwd, confirming root-level arbitrary file access across the target host.		
#1	CVE-2026-65400 Pre-auth SRP bypass → RCE as root (CVSS 9.8)	Critical
#12	Screen Sharing port 5900 exposed to network, enabling exploitation Screen Sharing port 5900 exposed to network, enabling exploitation	Medium
3	AdaptixC2 + SSH Backdoor	Persistence + C2 — T1071 + T1098
The AdaptixC2 Go-based framework was deployed providing the attacker with full shell, screenshot, upload/download capability over HTTPS (port 443). An RSA SSH keypair was generated and the public key appended to /root/.ssh/authorized_keys, creating a persistent root backdoor independent of the C2 channel.		
#10	AdaptixC2 Post-Exploitation full system compromise via Go C2	Critical
#7	Root SSH Key Backdoor persistent root access via authorized_keys	Critical
4	XMRig Monero Miner Deployment	Impact — T1496 + T1543
XMRig 6.26.0 was copied to /private/var/root/.config/sysmond to impersonate a legitimate macOS system daemon. A LaunchDaemon plist (com.xmr.miner.plist) with KeepAlive=true ensures the miner automatically restarts if killed. The miner consumed 98%+ CPU for Monero cryptocurrency mining with no alerting triggered.		
#8	XMRig masquerading as sysmond process-name evasion	High
#6	LaunchDaemon KeepAlive miner restarts automatically if killed	High
#9	No CPU/resource alerting sustained 98%+ CPU undetected	Medium
5	OSINT Attribution (Tookie-OSINT)	Reconnaissance — T1591

Tracked C2C2T, enumerated social media accounts linked to the user name, attacker providing threat actor attribution data. DMCA risk query against attacker domain.com mapped the attacker's mail infrastructure, compromising the phishing origin and enabling full domain blocking across perimeter defenses.	
Identified tributed	Medium
tion	IR Cycle — Contain / Eradicate / Recover
C2C2T, which compromised the personalizing process immediately eradicated. LaunchDaemon plist and systemd binary removed from disk. Detection rules deployed to detect in future. Detection rule updated with covering new plist file in /Library/LaunchDaemons. Unauthenticated Screen Sharing sessions, outbound port 443 from system processes, and sustained CPU spikes. System confirmed remediated.	
nce date.sh (also present)	High
ting l without approval	High

VULNERABILITY SCOREBOARD

#1 Screen Sharing RCE	Critical
#2 VBA Download Cradle	High
#3 No Macro Controls	High
#4 C2 Domain in Doc	Medium
#5 LaunchAgents Persist	High
#6 LaunchDaemon KeepAlive	High
#7 Root SSH Backdoor	Critical
#8 XMRig as sysmond	High
#9 No CPU Alerting	Medium
#10 AdaptixC2 C2	Critical
#11 No App Whitelist	High
#12 Port 5900 Exposed	Medium

DETECTION STACK

- Wazuh SIEM
- Sigma rules (6)
- macOS Audit Logs
- LaunchDaemon watcher
- Process hash baseline
- DNS sinkhole
- EDR (recommended)

ANALYST DECLARATION

All commands executed inside the GraySentinel GrayOS sandbox environment. No real systems were targeted. All artifacts are defensive and educational. Exploit code not reproduced; only detection and remediation artifacts included.

Eswar Mahalingam

Blue Team Operator & Trainee

GS-STU-DSOU-2026-039A

10 September 2026

DETECTION ENGINEERING — SIGMA RULES

```
title: GraySentinel DSOU Day2 - macOS Miner Attack Chain Detection
id: gs-dsou-day2-2026
status: experimental
description: >
  Detects indicators across the macOS Miner Attack Chain –
  phishing macro delivery, CVE-2026-65400 Screen Sharing exploit,
  AdaptixC2 C2 beacon, XMRig process masquerade, LaunchDaemon
  persistence, and SSH key backdoor implant.
author: Eswar Mahalingam | GS-STU-DSOU-2026-039A
date: 2026-09-10
tags:
  - attack.initial_access      # T1566 Phishing
  - attack.execution          # T1203 Exploit Public App
  - attack.persistence        # T1543 LaunchDaemon | T1098 Account Manip
  - attack.command_and_control # T1071 App Layer Protocol
  - attack.impact              # T1496 Resource Hijacking
logsource:
  product: macos
  category: process_creation
detection:
  # Tripwire 1: oletools or VBA macro download cradle execution
  macro_cradle:
    CommandLine|contains:
      - 'olevba'
      - 'URLDownloadToFile'
      - 'suspicious_document.doc'
  # Tripwire 2: Screen Sharing exploit PoC execution
  screen_sharing_exploit:
    CommandLine|contains:
      - 'poc_screensharing.py'
      - '5900'
  # Tripwire 3: XMRig masquerading as sysmond
  xmrig_masquerade:
    Image|endswith: '/sysmond'
    CommandLine|contains:
      - 'xmrig'
      - '- -coin'
      - 'monero'
  # Tripwire 4: New LaunchDaemon plist creation (miner persistence)
  launch_daemon_miner:
    EventID: 11 # file create
    TargetFilename|startswith: '/Library/LaunchDaemons/'
    TargetFilename|contains: 'miner'
  # Tripwire 5: SSH authorized_keys modification by root
  ssh_backdoor:
    CommandLine|contains:
      - 'authorized_keys'
      - 'ssh-keygen'
    User: root
  # Tripwire 6: AdaptixC2 agent execution
  adaptixc2_agent:
    CommandLine|contains:
      - 'agent.macos'
      - '- -server'
      - '- -port 443'
  condition: >
    macro_cradle or screen_sharing_exploit or xmrig_masquerade
    or launch_daemon_miner or ssh_backdoor or adaptixc2_agent
falsepositives:
  - Legitimate oletools usage by security analysts (tune by user)
  - Authorised SSH key management (verify against change ticket)
  - Genuine sysmond process (verify binary hash against Apple baseline)
level: critical
```

BLUE TEAM RECOMMENDATIONS

IMMEDIATE (0–24 h)

- Patch CVE-2026-65400: apply Apple Security Update; disable Screen Sharing if unused; firewall port 5900.
- Rotate all SSH keys; audit /root/.ssh/authorized_keys on all macOS endpoints.
- Kill and remove any sysmond binary not matching Apple's baseline SHA-256.
- Block attacker-domain.com and 192.168.1.100 at DNS/firewall perimeter.

SHORT-TERM (1–7 days)

- Deploy Wazuh rules (detection-rule-wazuh.xml) covering all 6 tripwires above.
- Enable macro execution blocking in Office; enforce document signing policy.
- Implement application whitelisting (Gatekeeper + MDM) — block unsigned binaries.
- Configure CPU usage alerting: alert on any process sustaining >80% CPU for >5 min.

STRATEGIC (30 days)

- Integrate threat-intel feed for C2 domain/IP blocking (block attacker infrastructure at scale).
- Conduct SOC tabletop exercise simulating full macOS miner attack chain.

- Extract DPM771.5 manual with an all remote access services to mitigate hardware/agent exposures.
- Merge DPM with behavioural detection for process name misquarante and Launch/Screen abuse.

DD — all 6 phases documented with command-level evidence and rule mapping

over 100k, persistence removed, detection rules deployed to DPM

6/10/2024 10:00:00 — domain and mail server blocked at perimeter

aySentinel DSOU grader validation — GS-STU-DSOU-2026-039A.